

PROJECT DESIGN TASK

Presented by:

- Suraj Krishan 25486679
 - NETWORK SECURITY
- Asher Khan 25558697
 - DATA STORAGE/SECURITY
- Edwin Zhang 25628619
 - BUSINESS CONTINUITY DISASTER RECOVERY (BCDR)

Table of contents

PROJECT DESIGN TASK	1
1.0 INTRODUCTION	3
2.0 EXECUTIVE SUMMARY	3
3.0 REQUIREMENTS	4
4.0 DESIGN SPECIFICATIONS	5
5.0 Organisational policies	7
1. Data Governance Policies	7
2. Network Policies	7
3. Business Continuity and Disaster Recovery Policies	8
6.0 NETWORK SECURITY	8
6.1 Amazon VPC (Virtual Private Cloud)	8
6.2 Subnets and Route Tables	9
6.3 Security Groups & NACLs	11
6.4 AWS Web Application Firewall (WAF)	12
6.5 Roles and Functions of AWS Network Security Services	15
7.0 DATA STORAGE/SECURITY	15
7.1 Encryption & Key Management	15
7.2 Durability, Availability & Lifecycle Management	17
7.3 Backup & Retention Policies	18
7.4 Roles & Functions of AWS Storage / Data Security Services	18
8.0 BUSINESS CONTINUITY DISASTER RECOVERY (BCDR)	19
8.1 Recovery Planning with Multi-AZ & Multi-Region Deployment	19
8.2 Automated Backup & Replication	20
8.3 Disaster Recovery Strategies	21
8.4 Continuous Monitoring & Testing	22
8.5 Roles & Functions of AWS BCDR services	23
9.0 SLA AGREEMENTS	24
10.0 Conclusion	25
11.0 Reference	25

1.0 INTRODUCTION

A financial services organisation moving to AWS PaaS must build security into every layer of its cloud environment. The new AWS-based platform will use managed services (Elastic Beanstalk, Lambda, RDS, etc.) for application hosting.

Nowadays many institutions choose to use AWS cloud as their first options. Cloud computing could bring new opportunities for the financial services industry. But at the same time they will need to face the challenges in balancing digital transformation with stringent security requirements. The business is required to navigate a complex regulatory landscape while protecting financial data. A successful cloud migration requires careful consideration in multiple perspectives, including effective measures in network protection, application security, data governance, regulatory compliance and an effective business continuity disaster recovery plan.

In this report we will introduce some of the AWS security features available to financial institutions that mainly focus on network security, data protection and business continuity disaster recovery (BCDR) plans. Also, we will explore how AWS helps the organisation move to the cloud while keeping their financial operations secure and compliant.

2.0 EXECUTIVE SUMMARY

With companies increasing their adoption of cloud technologies, protecting customer data and securing financial services is the forefront of migrating. This report presents a design specification of a security solution for a financial services organisation operating in an AWS PaaS model. The solution defines functional, non-functional, and regulatory requirements in alignment with AWS technical specifications and financial industry standards.

AWS services such as VPC, Security Groups, WAF, GuardDuty, CloudWatch, S3, RDS, and KMS are included in functional requirements to address network security, data encryption, and continuous monitoring. The non-functional requirements focus on high availability, data backup, disaster recovery, and security auditing to ensure resilience and operational continuity. The regulatory requirements are defined in accordance with key compliance obligations, including the General Data Protection Regulation (GDPR) and Privacy Act 1988.

Further, the report outlines the organisational policies needed to enforce access control, compliance monitoring, and governance. Each component of the design network and application security with monitoring, compliance and governance, and data security and storage is explained in detail, including the AWS services, roles, and functions that support it. Service Level Agreements (SLAs) relevant to the chosen services are also discussed to ensure reliability and accountability.

The overall design provides a secure, compliant, and scalable AWS environment that safeguards customer trust while enabling the organisation to meet both technical and regulatory requirements.

3.0 REQUIREMENTS

Req No	Functional Requirements
F1	Secure network control for incoming and outgoing traffic
F2	Protection against web traffic and denial of service (Dos) attacks
F3	Continuous monitoring, logging, and threat detection
F4	Encryption of financial data at rest and in transit
F5	Backup and recovery for financial records and data
F6	Governance and compliance enforcement across multiple accounts
F7	Audit and track all API calls and administrative actions

Req No	Non-Functional Requirements
NF1	High availability through multi-zone deployment
NF2	Scalability to handle peak financial transactions
NF3	Reliability through automated failover and recovery
NF4	Data durability for long-term financial storage
NF5	Protection against large-scale DDoS attacks
NF6	Security audit and compliance validation
NF7	Monitoring and automated alerts for suspicious activity

Req No	Regulatory Requirements
R1	Comply with data privacy laws like Australia's Privacy Act 1988 and GDPR.
R2	Protect payment information following PCI DSS standards.
R3	Follow APRA guidelines to secure financial data and ensure resilience.
R4	Meet SOX requirements for accurate financial reporting.

R5	Implement ISO 27001 cybersecurity standards.
R6	Retain financial records for auditability and traceability.
R7	Report to regulators and control administrative/API actions to prevent fraud.

4.0 DESIGN SPECIFICATIONS

For any cloud-based application, having a secure and reliable architecture is essential. Protecting data, maintaining system continuity, and ensuring user trust are top priorities. The application is designed following cloud security best practices, and the diagram below (Fig 1) shows the AWS cloud architecture, with the technical specifications outlined below.

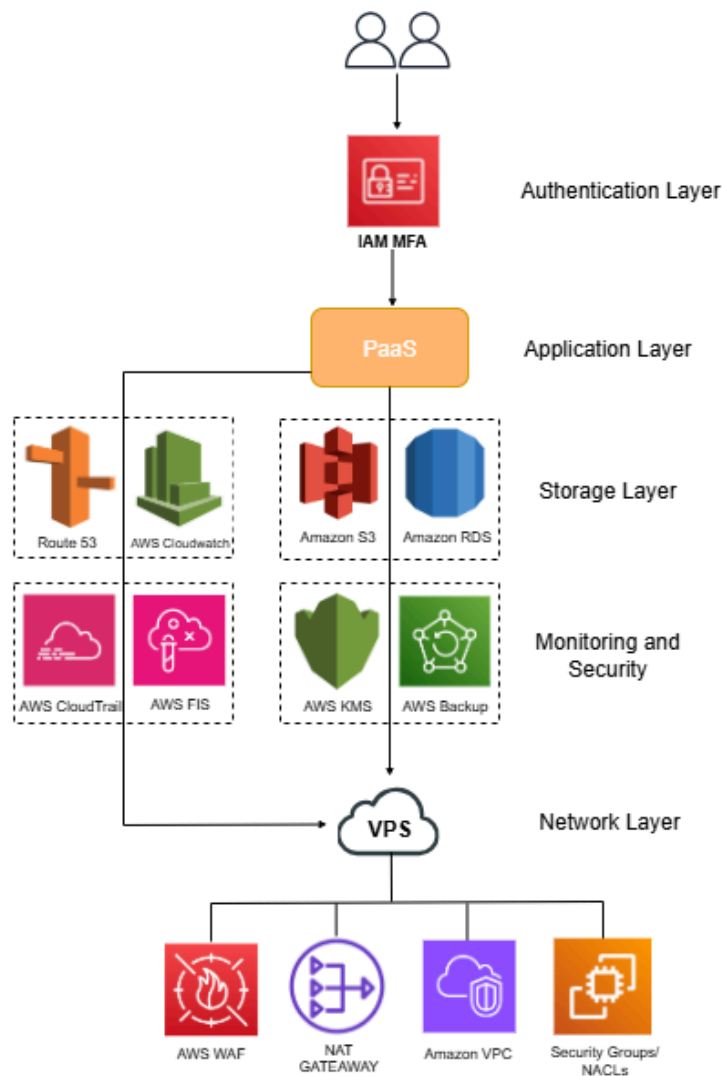


Figure 1: Proposed Cloud Architecture, Security & BCDR Layers

Authentication Layer

- AWS IAM with MFA - Fine-grained, MFA-enabled, role-based authentication to all resources.
- MFA - Require MFA for sensitive activities.
- Integrate with the PaaS layer to make sure only authorised app access the resource.

Application Layer

- PaaS - Hold scalable app logic and business services.
- Managed environment - No infrastructure overhead.
- Interacts with storage, monitoring, security etc to run smoothly.

Storage Layer

- Amazon S3 - Holds files, backups, static assets; Amazon RDS - Holds structured data.
- Highly available, durable and automatically backed up.
- Interacts with monitoring, security.

Monitoring and Security Layer

- AWS CloudTrail - Log activity.
- AWS FIS - Inject faults to test resiliency.
- AWS KMS - Manage encryption.
- AWS Backup - Centralised backups.
- Auditing, Threat detection, Automated recovery, Encryption etc to comply.
- Uses fault injection to test resiliency.

Network Layer

- VPS - Holds apps.
- VPC - Holds isolated resources.
- WAF and Security Groups - Protects the instance from attacks.
- NAT Gateway - Allows secure access to the internet.
- Network isolation - Firewall protection - Allow only intended traffic to flow.
- ACLs - Allow only intended traffic to flow.

The design of the report covers 5 main components: Authentication, Application, Storage, Monitoring and Security with Network.

SI No.	Component	Roles	Functions
1	Authentication Layer	Managing secure access.	Controls access for users and roles (IAM), MFA; talk to apps (authorised access).
2	Application Layer	Managed, scalable environment for running apps.	Deploy and run business logic in a managed, scalable environment.
3	Storage Layer	Storing and managing data.	Store structured and unstructured data (S3, RDS); durability, availability, automatic backups.
4	Monitoring and Security Layer	Compliance, auditing, resilience.	Monitoring activity (CloudTrail), protecting data (KMS), automatic recovery (AWS Backup), resilience (FIS).

5	Network Layer	Secure communications, controlling traffic.	Isolating resources (VPC), protecting from attacks (WAF, Security Groups), controlling traffic (NAT, ACLs).
---	---------------	---	---

5.0 Organisational policies

Organisational policies are essential to ensure that AWS security measures are effectively implemented, monitored, and maintained. These policies are crucial to define the rules and responsibilities for the protection of financial services. Furthermore they must ensure compliance with regulatory requirements such as GDPR and the Australian Privacy Act 1988.

1. Data Governance Policies

Ensures the security, integrity, and compliance of data stored and processed in AWS.

1.1 Encryption Policies: Monitor and implement the use of AWS KMS for encrypting data at in S3, and other storage services, and enforce TLS/HTTPS for data in transit

1.2 Logging and Monitoring Policies: Enabling AWS CloudTrail, GuardDuty, and CloudWatch to continuously monitor account activity and irregular patterns.

1.3 Audit and Reporting Policies: Conduct regular internal audits, compliance checks, and reporting procedures to comply with GDPR, Privacy Act 1988, and financial industry standards.

2. Network Policies

Controls how access to AWS resources is granted, monitored, and restricted through VPC

2.1 VPC Configuration Policies: Ensure network segmentation, routing, and subnet isolation in accordance with least privilege access principles.

2.2 Security Group and NACL Policies: Implement firewall rules for incoming and outgoing traffic to monitor and deny unauthorised access

2.3 Web Application Firewall (WAF) Policies: Define rules to prevent web attacks and exploits

3. Business Continuity and Disaster Recovery Policies

Manages the ability to recover from system failures or disasters whilst mitigating the likelihood of disruptions

3.1 Disaster Recovery Planning: Clearly defined Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) for critical services using AWS Backup and links to the business critical operations.

3.2 Periodic Testing Policies: Ensure regular testing of backup, recovery, and failover mechanisms to analyse any discrepancies and evaluate effectiveness.

6.0 NETWORK SECURITY

Network security is a fundamental component of securing financial applications in the cloud, as these services process highly sensitive information from payment transactions to customer identities, therefore protecting the network layer is essential to prevent unauthorised access, data breaches, and any forms of disruptions. In AWS, network security can be achieved via combining isolation, controlled access, traffic monitoring, and threat prevention mechanisms. Utilising AWS services within a Virtual Private Cloud (VPC), additional layers of protection, such as, Subnets/Routes, Security Groups and Network Access Control Lists (NACLs), and Web Application Firewalls (WAF), which ensure that only legitimate traffic reaches the applications.

These are an elaboration on the following chosen services to provide network security:

6.1 Amazon VPC (Virtual Private Cloud)

The Amazon Virtual Private Cloud (VPC) provides an isolated section of the AWS cloud where resources and communication are controlled by the user. Public and private subnets can be utilised to separate sensitive databases and public applications, allowing the user to control where data goes and who views it whilst having a secure and flexible environment in the cloud to run operations.

Create VPC [Info](#)

A VPC is an isolated portion of the AWS Cloud populated by AWS objects, such as Amazon EC2 instances.

VPC settings

Resources to create [Info](#)
Create only the VPC resource or the VPC and other networking resources.

☒ VPC only ☐ VPC and more

Name tag - optional
Creates a tag with a key of 'Name' and a value that you specify.

CloudSecurity

IPv4 CIDR block [Info](#)
☒ IPv4 CIDR manual input
☐ IPAM-allocated IPv4 CIDR block

IPv4 CIDR
10.0.0.0/16
CIDR block size must be between /16 and /28.

IPv6 CIDR block [Info](#)
☒ No IPv6 CIDR block
☐ IPAM-allocated IPv6 CIDR block
☐ Amazon-provided IPv6 CIDR block
☐ IPv6 CIDR owned by me

Tenancy [Info](#)
Default

Tags
A tag is a label that you assign to an AWS resource. Each tag consists of a key and an optional value. You can use tags to search and filter your resources or track your AWS costs.

Key **Value - optional**

You can add 49 more tags

[Cancel](#) [Preview code](#)

Figure 2: VPC creation

Procedure:

1. Navigate to the VPC section in the AWS Console.
2. Choose VPC only as the setting (VPC and more is more secure, however for this example it is purely to create the VPC)
3. Create a nametag for it
4. Pick IPv4 CIDR manual input and create an IP range from /16 to /28 (e.g 10.0.0.0/16).
5. Leave IPv6 CIDR block as No unless specifically required for mass usage .
6. Keep Tenancy as Default so instances use shared hardware unless otherwise required.
7. Create VPC

6.2 Subnets and Route Tables

Subnets divide a VPC into smaller networks for better organisation and security. Public subnets are used for resources that need internet access, such as app servers, while private subnets host databases and resources that should not be exposed. Furthermore, route tables then control how traffic flows, public subnets route traffic through an Internet Gateway, while private subnets send outbound traffic through a NAT Gateway. This ensures secure routing between internal and external networks and diversification of workloads.

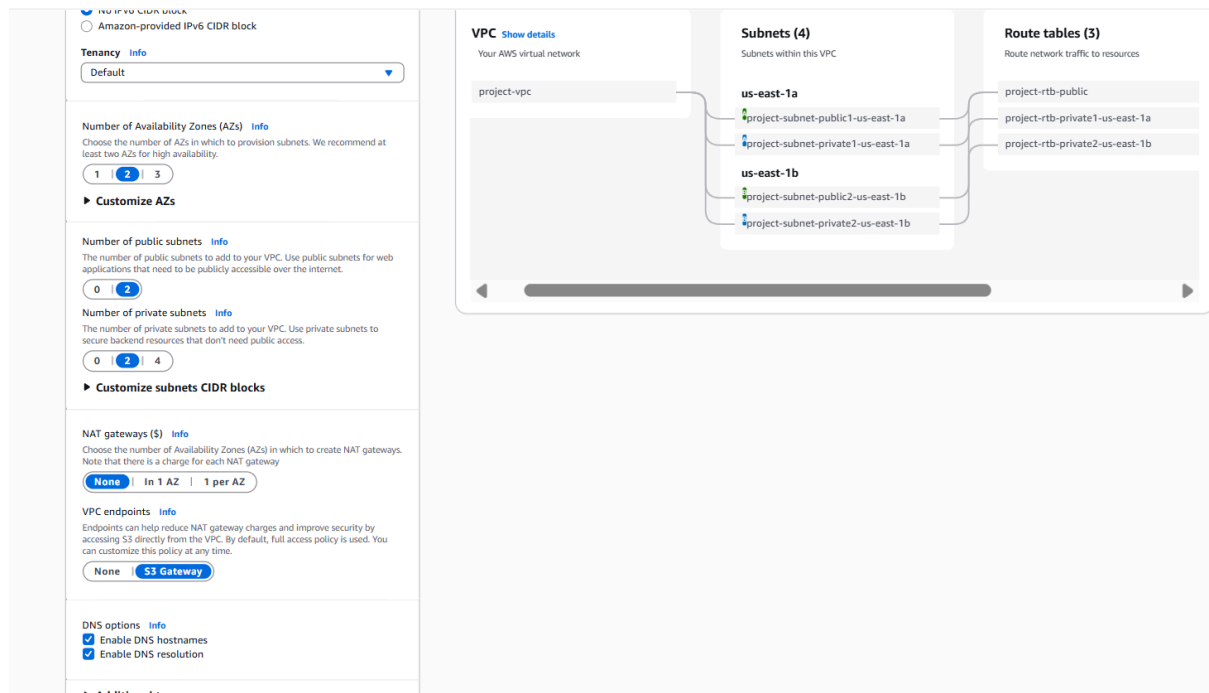


Figure 3: Subnets and Route table implementation

Procedure:

1. Create VPC
2. Select VPC and more, there will be more configuration options below tenancy
3. Select availability zones and the amount e.g us-east-1a and us-east-1b to ensure high availability
4. Select amount of public subnets and configure each to be in both availability zones to communicate with the internet
5. Repeat step 4 with the private subnets as well ,which will not communicate with the internet as they are for backend resources
6. Associate (project-rtb-public) the public route table with both public subnets
7. Associate private subnets with their private route tables to configure routes for only internal traffic and NAT gateway access
8. Enable NAT gateway per availability zone to allow private subnets to reach the internet outbound only whilst blocking inbound internet traffic
9. Configure VPC endpoint, utilise S3 gateway to allow private subnets to reach the s3 without interacting with the public internet to maximise security as traffic never leaves the s3 backbone

6.3 Security Groups & NACLs

Security Groups and Network Access Control Lists (NACLs) function as firewalls at different layers within a VPC. Security Groups manage incoming and outgoing traffic for resources at the instance level, while NACLs work at the subnet level, applying broader rules to all resources in that subnet. Together, they provide layered protection by filtering out suspicious and unauthorised traffic and only allowing necessary ports.

Figure 4: Security Group Creation

Procedure

(Security Group Example):

1. Navigate to EC2 then Security Groups.
2. Create a Security Group and assign it to the created VPC.
3. Add a description indicating its purpose
4. Add inbound rules depending on the goal e.g Allow HTTPS (443) from the internet or private IP addresses such to allow access from known IPs.
5. Add outbound rules to either all ips or restricted ones
6. Attach the Security Group to application resources.
7. Once satisfied, select (create security group).

NACLs apply similar rules to block or allow ranges of traffic, however this is done across the entire subnets as an additional layer of security over security groups.

6.4 AWS Web Application Firewall (WAF)

AWS WAF protects web applications from exploits such as SQL injection, cross-site scripting (XSS), and HTTP floods. By filtering fraud requests and allowing only legitimate traffic, it protects web applications. AWS WAF can integrate its abilities with an Application Load Balancer to automatically block known exploit patterns.

The screenshot displays the AWS WAF console interface for Step 1 of creating a Web ACL. The left sidebar shows a five-step process: Step 1 (Describe web ACL and associate it to AWS resources), Step 2 (Add rules and rule groups), Step 3 (Set rule priority), Step 4 (Configure metrics), and Step 5 (Review and create web ACL). The main content area is titled 'Describe web ACL and associate it to AWS resources' and includes an 'info' link.

Web ACL details

Resource type
Choose the type of resource to associate with this web ACL. Changing this setting will reset the page.

- ☐ Global resources (CloudFront Distributions, CloudFront Distribution Tenants and AWS Amplify Applications)
- ☒ Regional resources (Application Load Balancers, Amazon API Gateway REST APIs, Amazon App Runner services, AWS AppSync APIs, Amazon Cognito user pools and AWS Verified Access Instances)

Region
Choose the AWS Region to create this web ACL in. Changing this setting will reset the page.

US East (N. Virginia) ▼

Name
CloudSecurity
The name must have 1-128 characters. Valid characters: A-Z, a-z, 0-9, -, (hyphen), and _ (underscore).

Description - optional
EXAMPLE ON WAF CREATION
The description can have 1-256 characters.

CloudWatch metric name
CloudSecurity
The name must have 1-128 characters. Valid characters: A-Z, a-z, 0-9, -, (hyphen), and _ (underscore).

Associated AWS resources - optional (0) Remove Add AWS resources

Find associated AWS resources

Name	Resource type	Region
No items No items to display		

Cancel Next

Figure 5.0: STEP 1 of WAF creation

Step 1

Describe web ACL and associate it to AWS resources

Step 2

Add rules and rule groups

Step 3

Set rule priority

Step 4

Configure metrics

Step 5

Review and create web ACL

Add rules and rule groups [Info](#)

A rule defines attack patterns to look for in web requests and the action to take when a request matches the patterns. Rule groups are reusable collections of rules. You can use managed rule groups offered by AWS and AWS Marketplace sellers. You can also write your own rules and use your own rule groups.

Rules (0)

Edit Delete Add rules ▾

If a request matches a rule, take the corresponding action. The rules are prioritized in order they appear.

	Name	Capacity	Action
No rules.			
You don't have any rules added.			

Web ACL capacity units (WCUs) used by your web ACL

The WCUs used by the web ACL will be less than or equal to the sum of the capacities for all of the rules in the web ACL.

The total WCUs for a web ACL can't exceed 5000. Using over 1500 WCUs affects your costs. [AWS WAF Pricing](#)

0/5000 WCUs

Default web ACL action for requests that don't match any rules

Default action

☒ Allow

☐ Block

► Custom request - optional

Token domain list - optional

Enable the use of tokens across multiple protected applications by entering the application domains here. Tokens are used by the Challenge and CAPTCHA rule actions, the application integration SDKs, and the ATP and Bot Control managed rule groups. [Learn more](#)

Add token domain

You can add 10 more domains

Figure 5.1: STEP 2 of WAF creation

AWS WAF

>

Web ACLs

>

Create web ACL

Step 1

Describe web ACL and associate it to AWS resources

Step 2

Add rules and rule groups

Step 3

Set rule priority

Step 4

Configure metrics

Step 5

Review and create web ACL

Set rule priority [Info](#)

Rules (0)

▲ Move up ▼ Move down

If a request matches a rule, take the corresponding action. The rules are prioritized in order they appear.

	Name	Capacity	Action
No rules.			
You don't have any rules added.			

Cancel

Previous

Next

Figure 5.2: STEP 3 of WAF creation

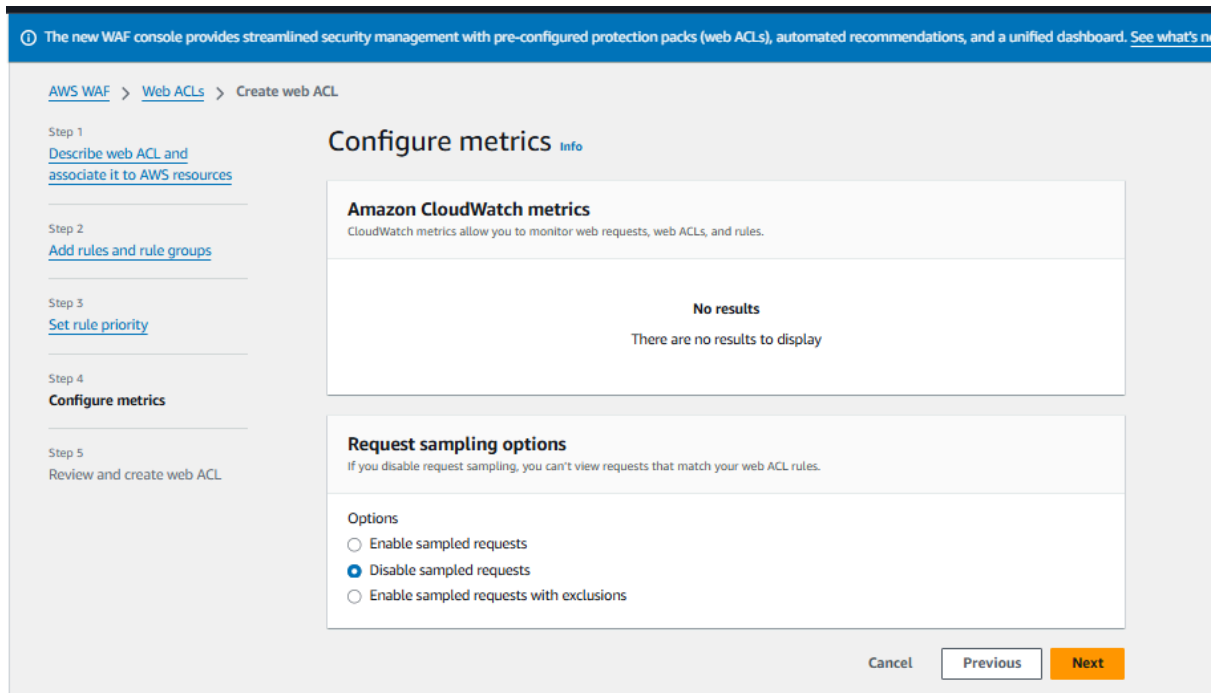


Figure 5.3. STEP 4 of WAF creation

Procedure:

1. Navigate to AWS WAF in the AWS Console.
2. Select create a Web ACL
3. Complete step 1 Web ACL details, choose a name, select a resource type e.g Cloudfront for global or Application Load Balancer for regional.
4. Complete step 2 via adding specific rules OR selecting from AWS managed rules and purchasing specific rules based on user benefit, note the Web ACL capacity units which show total allowance usage, after that set default Web ACL to either deny or accept actions that do not comply with the set rules.
5. Complete step 3 by assigning priority levels to the set rules with lower numbers being evaluated first
6. Complete step 4 by enabling metrics to monitor the traffic patterns and activity
7. Complete step 5 which is the final review of steps 1-4 and create.

6.5 Roles and Functions of AWS Network Security Services

AWS Service	Role	Function
Amazon VPC 	Creates an isolated environment in the cloud	Launch workloads and data in a separated cloud network with custom IP ranges allowing authorised personnel
Subnets/Route tables 	Divides workloads into public and private zones	Public subnets for internet involved services and private subnets for databases within the backend. Route tables define incoming and outgoing traffic.
Security Groups/NACLs 	Instance level and subnet level firewalls	Oversee the allowance or denial of traffic from the niche level to the broad level, via applying rules to regulate specific access.
AWS WAF 	Web application firewall	Protects applications from attacks and malicious requests by filtering web traffic and requests that do not comply with set rules or AWS rules.

7.0 DATA STORAGE/SECURITY

Storing financial data in the cloud comes with both great benefits (scalability, managed services, cheaper long-term archive) and important responsibilities (privacy, immutability, recoverability). In this section we break the topic into practical pieces so a student reader and our team can see what to configure, why it matters, and how to do it step-by-step. We cover encryption & key management, durability and lifecycle, backups & retention, and finish with a compact table summarising the roles of the main AWS storage/security services.

7.1 Encryption & Key Management

Encryption is the baseline for protecting sensitive financial records: encrypt data at rest and in transit, and manage keys centrally so access can be audited and rotated. AWS KMS is the

recommended central key service and integrates with S3, RDS, EBS and Secrets Manager (KMS acts as the “root of trust” for encryption operations).

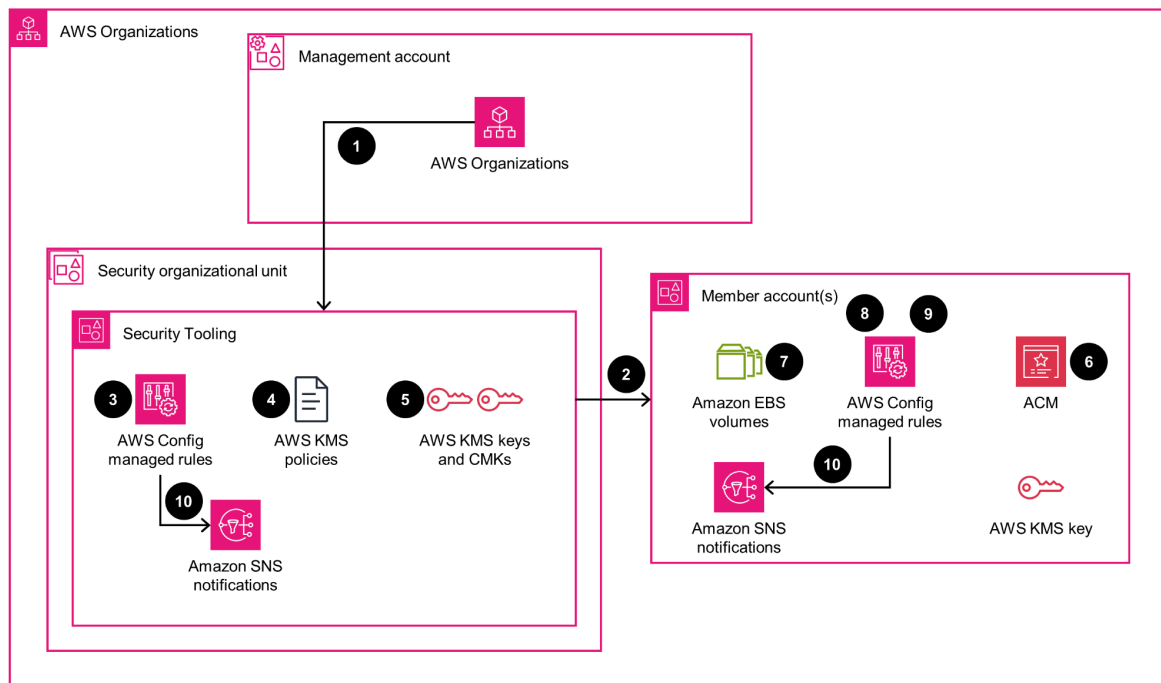


Figure 6.0: Encryption & Key Management

Practical tip: For very sensitive fields (e.g., full PAN or SSN), you can apply field-level encryption at the edge (CloudFront + Lambda@Edge) so data arrives already encrypted before hitting persistent storage — see the field-level encryption blog/diagram (Figure 7).

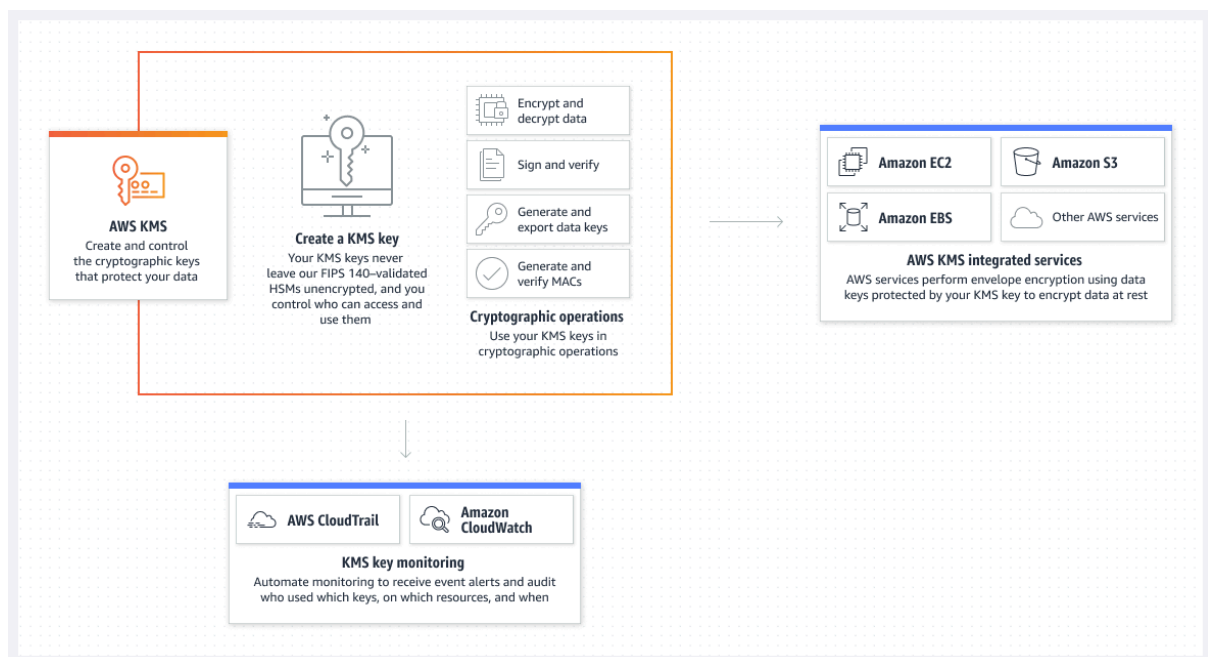


Figure 6.1: AWS KMS overview

Figure 6.1 illustrates the AWS KMS process flow, from key creation to encryption/decryption and its integration with multiple AWS services such as S3, RDS, and Secrets Manager. This

shows how KMS acts as the backbone of our encryption strategy, ensuring all sensitive data is protected under centralised key policies.

Procedure:

1. Console → AWS KMS → Create key → choose Symmetric CMK → define an administrative key policy (limit to a security/admin role).
2. Console → S3 → select bucket → Properties → Default encryption → select SSE-KMS and choose the CMK you created (or choose SSE-S3 for managed keys). This enforces server-side encryption for all new objects.
3. IAM policies: add kms:Decrypt / kms:Encrypt only to roles that actually need data access (principle of least privilege). Log key usage via CloudTrail.

7.2 Durability, Availability & Lifecycle Management

Financial data must be durable and available for audits and operations. Amazon S3 is designed for 11-nines durability and stores data across multiple Availability Zones, making accidental loss extremely unlikely. For relational data, Amazon RDS supports encryption at rest (AES-256) and can be deployed Multi-AZ for automatic failover.

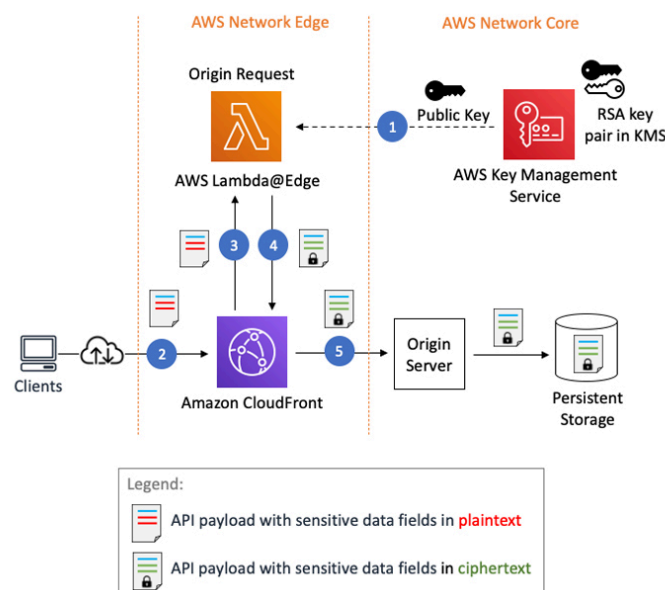


Figure 7: Data lifecycle encryption diagram

Procedure:

1. Console → S3 → Bucket → Management → Lifecycle rules → Create rule to transition objects after X days to S3 Glacier Flexible Retrieval or Glacier Deep Archive (encrypted objects remain encrypted through transition).
2. If you require WORM/immutable storage for compliance, enable S3 Object Lock (Compliance mode) on a versioned bucket before storing records. Object Lock prevents deletion/overwrite for the retention period and has been assessed for SEC/FINRA use cases.

3. For databases: when creating an RDS instance, choose the Enable Encryption option and select the CMK; enable Multi-AZ for high availability and automated synchronous replication.

Practical test: schedule regular restore drills (quarterly) to validate RTO/RPO and to prove to auditors that backups are recoverable.

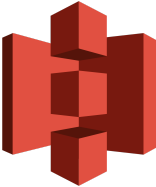
7.3 Backup & Retention Policies

Backups must be automated, immutable where required, and discoverable for audits. AWS Backup centralises backup policies for RDS, EFS, DynamoDB and more, and Backup Vault Lock can enforce immutable backup retention that meets regulatory needs.

Procedure:

1. Console → AWS Backup → Backup plans → Create a plan (define frequency, lifecycle, vault). Assign resources (RDS DB, EFS file systems, S3 via DataSync).
2. Create a Backup Vault → enable Vault Lock configuration (set retention period and lock policy). Once Vault Lock is in place, retention rules cannot be shortened. AWS notes Vault Lock has been assessed for SEC 17a-4/CFTC/FINRA contexts.
3. Integrate with CloudTrail and AWS Config: send backup and vault events to CloudWatch/CloudTrail so auditors can trace backup creation, deletion attempts, and key usage.

7.4 Roles & Functions of AWS Storage / Data Security Services

AWS Service	Role	Function
Amazon S3 	Primary object store for files & archives	Highly durable object storage (11-nines), lifecycle transitions to Glacier, object versioning & Object Lock for WORM.
Amazon RDS 	Relational database for transactional records	Managed relational DB with AES-256 encryption at rest, automated backups, Multi-AZ failover.
AWS KMS 	Central key authority	Create/manage CMKs, audit key usage, integrate with S3/RDS/Secrets Manager.

AWS Backup 	Central backup orchestration	Policy driven backups across services, Vault Lock for immutable retention (compliance).
Secrets Manager 	Credentials & secret rotation	Store DB credentials/API keys securely, enable automatic rotation for RDS. (integrates with KMS)
S3 Glacier 	Long-term, low-cost archive	Cold storage for audit records; use lifecycle rules to transition objects.

8.0 BUSINESS CONTINUITY DISASTER RECOVERY (BCDR)

For financial institutions, downtime can bring negative impact to customer trust and regulatory compliance, which will make the business continuity and disaster recovery (BCDR) to become a core consideration for the institution. The key idea of BCDR is to ensure that financial services can continue operating even during unexpected outages and can have the ability to quickly recover from disruptions. In order to achieve this, AWS provides a resilient architecture designed to meet recovery time objectives (RTO) and recovery point objectives (RPO) to make sure that institutions can minimise data loss and achieve rapid recovery.

8.1 Recovery Planning with Multi-AZ & Multi-Region Deployment

AWS maintains system resiliency by spreading workloads across multiple regions or zones, so if one region or zone fails, critical applications like payment systems can automatically switch over using Route 53 and RDS Multi-AZ.

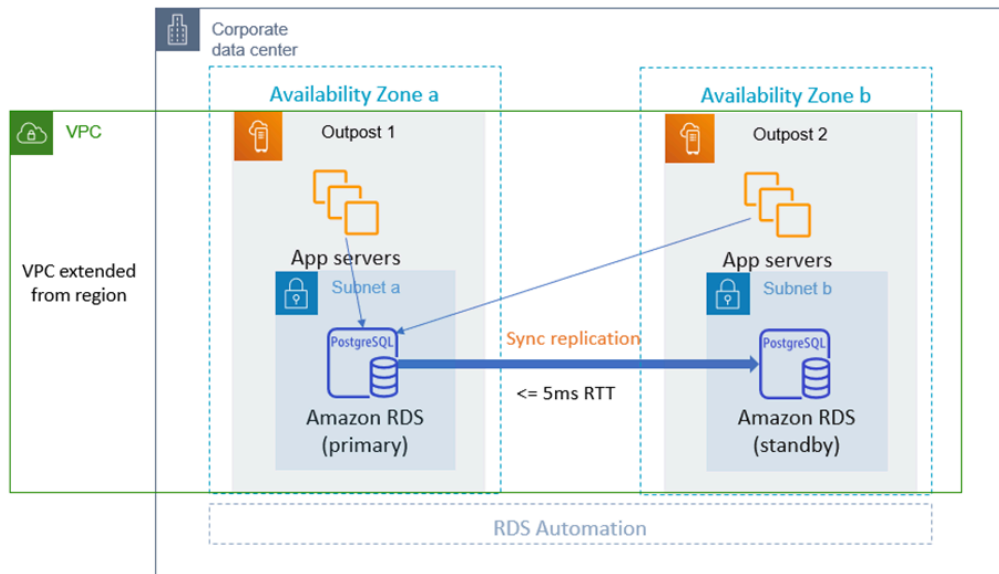


Figure 8: Multi-AZ High Availability Architecture

Procedure:

1. Open the AWS Management Console and create a new database in RDS.
2. Select the multi-AZ option to replicate the database in real time across two Availability Zones.
3. Enable automatic backups to ensure all transaction logs are saved.
4. Set up health checks in Route 53 to monitor the system.
5. Configure a failover routing policy so that if one region (e.g. Sydney) fails, traffic is redirected to another region (e.g. New Zealand).

8.2 Automated Backup & Replication

Even when disaster strikes, we still need to make sure that the data is safe and accessible. AWS provides help with this through tools like AWS Backup, which can automatically protect the data according to defined policies. Also, using services like S3 Cross-Region Replication (CRR) and DynamoDB Global Tables, which can replicate critical data across different regions, this can always be available when needed.

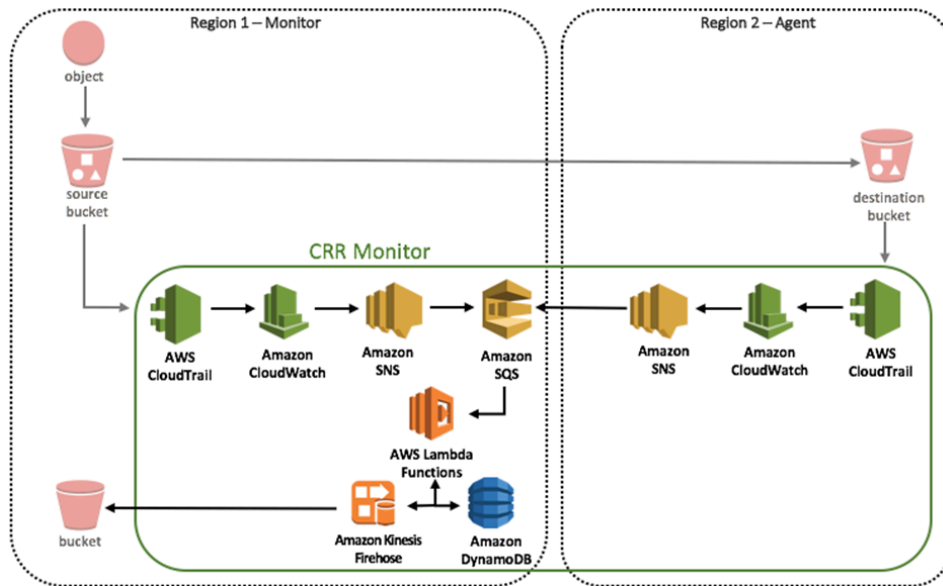


Figure 8.1: Workflow of Cross-Region Replication Monitor (CRR)

Procedure:

1. Open the AWS Backup console and create a backup plan.
2. Select the frequency of backups (e.g. daily) and how long to retain them.
3. Create a backup vault and enable vault lock to prevent the backups from being altered or deleted.
4. In the S3 console, set up replication rules:
5. Select Cross-Region Replication (CRR).
6. Select a destination bucket in another region (e.g. ap-southeast-1).
7. In DynamoDB, enable Global Tables so the database is automatically replicated across multiple regions.

8.3 Disaster Recovery Strategies

AWS offers four main recovery models designed to maximise recovery speed while minimising costs. Backup and restore is the most cost-effective option, but also the slowest, as the system can only be recovered after a failure. Pilot Light maintains a minimal version of the environment running, allowing for rapid scalability in the event of a disaster. Hot standby maintains a smaller, continuously running environment that can also be scaled when needed, while providing faster recovery at a moderate cost. Finally, the multi-site (hot standby) model is the most dependable option because it keeps fully active systems running in multiple regions at the same time, guaranteeing zero downtime, but it also comes with the highest cost.

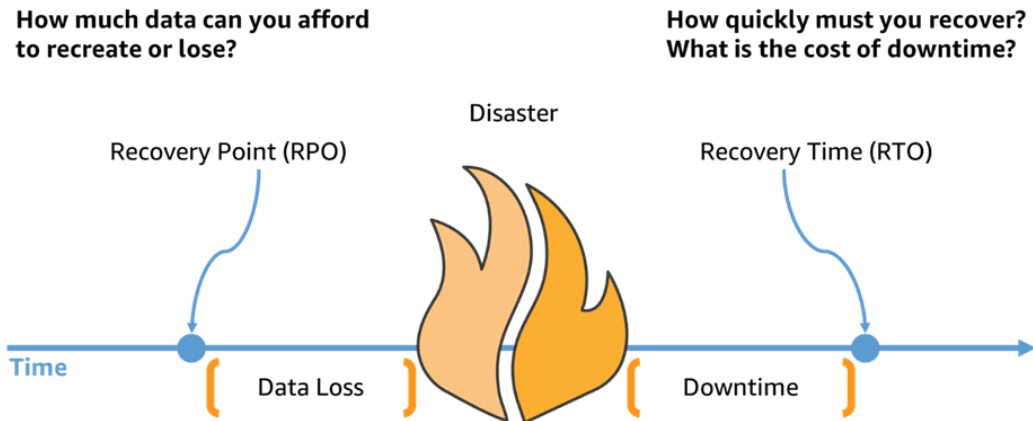


Figure 8.2: AWS Recovery time objective (RTO) and Recovery point objective (RPO)

Procedure:

1. Define the RTO (Recovery Time Objective) and RPO (Recovery Point Objective) for each workload.
2. Match the appropriate strategy to each workload:
3. Payment processing → Multi-site (hot standby).
4. HR system → Hot standby.
5. Historical archives → Backup and restore.
6. Deploy appropriate AWS services (e.g. RDS multi-AZ for databases, Auto Scaling groups for applications, and CRR for archives)

8.4 Continuous Monitoring & Testing

The institution needs to evaluate their BCPR plan to make sure that it will work when needed. AWS provides several tools to make it happen: CloudWatch can monitor system performance and health. CloudTrail will record with detailed logs of activity and changes for auditing, and the Fault Injection Simulator (FIS) allows teams to intentionally simulate failures to observe how applications and infrastructure respond.

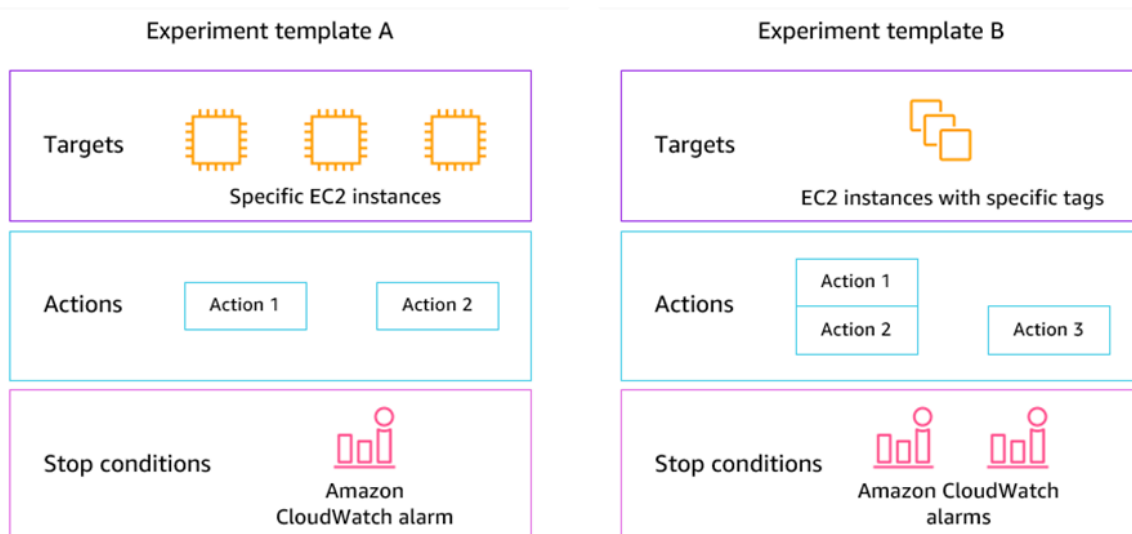
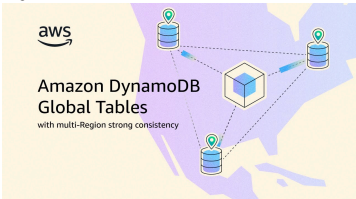


Figure 8.3: The concepts of AWS Fault Injection Service (FIS)

Procedure:

1. In the AWS Fault Injection Simulator (FIS), create experiment templates (e.g. shutting down EC2 instances in one Availability Zone).
2. Run experiments to evaluate that autoscaling and Route 53 failover are working correctly.
3. In CloudWatch, set alarms to trigger when recovery events occur.
4. In CloudTrail, review event history to audit and confirm recovery actions.
5. Conduct disaster recovery drills quarterly and document the results to demonstrate compliance.

8.5 Roles & Functions of AWS BCDR services

AWS Service	Role	Function
Amazon Route 53 	DNS failover & routing	Monitors system health and redirects traffic to healthy endpoints or alternate regions during outages.
DynamoDB Global Tables 	Multi-region replication	Automatically replicates databases across multiple regions for active-active availability.
AWS CloudWatch 	Monitoring	Tracks system performance and sets alarms to detect recovery events.
AWS CloudTrail 	Auditing	Records activity and changes for compliance and recovery verification.
AWS Fault Injection Simulator (FIS)	Resilience testing	Simulates failures such as instance shutdowns or network disruptions to

		validate recovery processes.
---	--	------------------------------

9.0 SLA AGREEMENTS

Service Level Agreements (SLAs) demonstrate an organisation's reasonable expectations for AWS service reliability. These agreements provide standard assurances in key areas such as security, compliance, and business continuity. The following SLAs are included in this report:

Network SLA's:

1. Amazon VPC SLA
2. AWS WAF SLA
3. Amazon GuardDuty SLA
4. Amazon CloudWatch SLA
5. AWS CloudTrail SLA

Storage SLA's:

1. Amazon S3 SLA
2. Amazon RDS SLA
3. AWS Backup SLA
4. AWS KMS SLA
5. AWS Secrets Manager SLA
6. Amazon S3 Glacier SLA

Business Continuity & Disaster Recovery (BCDR) SLA's:

1. Amazon Route 53 SLA
2. DynamoDB Global Tables SLA
3. AWS Fault Injection Simulator (FIS) SLA

10.0 Conclusion

In conclusion, the AWS PaaS security design provides a secure and compliant cloud environment for financial services at rest and in transit. By combining network isolation, encryption, monitoring, and disaster recovery planning, this solution addresses both functional and regulatory requirements such as GDPR and the Privacy Act 1988. Utilising AWS services such as VPC, Security Groups, RDS, KMS, and many more, the high availability of data will be present and the protection of sensitive data will be assured following the transition into the AWS cloud.

11.0 Reference

Amazon Web Services. (2023). *Amazon S3 data inventory and durability*. In *Amazon Simple Storage Service User Guide*. AWS Documentation.

<https://docs.aws.amazon.com/AmazonS3/latest/userguide/s3-data-inventory.html>

Amazon Web Services. (2023). *AWS Key Management Service overview*. In *AWS Key Management Service Developer Guide*. AWS Documentation.

<https://docs.aws.amazon.com/kms/latest/developerguide/overview.html>

Amazon Web Services. (2023). *Backup Vault Lock*. In *AWS Backup Developer Guide*. AWS Documentation. <https://docs.aws.amazon.com/aws-backup/latest/devguide/vault-lock.html>

Amazon Web Services. (2023). *Encrypting Amazon RDS resources*. In *Amazon Relational Database Service User Guide*. AWS Documentation.

<https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Overview.Encryption.html>

Amazon Web Services. (2019, May 9). *How to protect sensitive data for its entire lifecycle in AWS*. AWS Security Blog.

<https://aws.amazon.com/blogs/security/how-to-protect-sensitive-data-for-its-entire-lifecycle-in-aws/>

Amazon Web Services. (2023). *Lifecycle transition for storage classes*. In *Amazon Simple Storage Service User Guide*. AWS Documentation.

<https://docs.aws.amazon.com/AmazonS3/latest/userguide/lifecycle-transition-general-considerations.html>

Amazon Web Services. (2023). *Protecting data using server-side encryption*. In *Amazon Simple Storage Service User Guide*. AWS Documentation.

<https://docs.aws.amazon.com/AmazonS3/latest/userguide/UsingServerSideEncryption.html>

Amazon Web Services. (2023). *Using S3 Object Lock*. In *Amazon Simple Storage Service User Guide*. AWS Documentation.

<https://docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html>

Anwar, N. (2025, May 25). *Configuring EC2 Instance Backups with AWS Backup: A Complete Guide*. Medium; AWS in Plain English.

<https://aws.plainenglish.io/configuring-ec2-instance-backups-with-aws-backup-a-complete-guide-35731c9a0d1f>

AWS. (2019). Regions, Availability Zones, and Local Zones - Amazon Elastic Compute Cloud. Amazon.com.

<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/using-regions-availability-zones.html>

AWS. (2019). *Regions, Availability Zones, and Local Zones - Amazon Elastic Compute Cloud*. Amazon.com.

<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/using-regions-availability-zones.html>

Backup As A Service - AWS Backup - AWS. (2025, July 18). Amazon Web Services, Inc.

https://aws.amazon.com/backup/?nc2=type_a

Copy data from an S3 bucket to another account and Region by using S3 Batch Replication - AWS Prescriptive Guidance. (2022). Amazon.com.

<https://docs.aws.amazon.com/prescriptive-guidance/latest/patterns/copy-data-from-s3-bucket-to-another-account-region-using-s3-batch-replication.html>

Catching Up on Some Recent AWS Launches and Publications | Amazon Web Services. (2017, September 20). Amazon Web Services.

<https://aws.amazon.com/blogs/aws/catching-up-on-some-recent-aws-launches-and-publications/>

Cross region replication in Amazon ECR has landed | Amazon Web Services. (2020, December 8). Amazon Web Services.

<https://aws.amazon.com/blogs/containers/cross-region-replication-in-amazon-ecr-has-landed/>

Disaster Recovery with AWS managed services, Part 1: Single Region | Amazon Web Services. (2021, November 12). Amazon Web Services.

<https://aws.amazon.com/blogs/architecture/disaster-recovery-with-aws-managed-services-part-i-single-region/>

Deploy Amazon RDS on AWS Outposts with Multi-AZ high availability | Amazon Web Services. (2022, May 5). Amazon Web Services.

<https://aws.amazon.com/blogs/database/deploy-amazon-rds-on-aws-outposts-with-multi-az-high-availability/>

Eliot, S. (2021, April 5). *Disaster Recovery (DR) Architecture on AWS, Part I: Strategies for Recovery in the Cloud*. Amazon Web Services.

<https://aws.amazon.com/blogs/architecture/disaster-recovery-dr-architecture-on-aws-part-i-strategies-for-recovery-in-the-cloud/>

Free Cloud Computing Services - AWS Free Tier. (2025, September 18). Amazon Web Services, Inc.

https://aws.amazon.com/free/?trk=6398a148-690a-4bd5-895e-a43ecb4844fb&sc_channel=ps&ef_id=Cj0KCQjw58PGBhCkARIsADbDilyjD2_FMbpImG5KaYHxDJImzFalzq6HIBO7TS8mfv3U987p2y9PbDlaAuW2EALw_wcB:G:s&s_kwcid=AL

KodeKloud Notes. (2025). KodeKloud Notes.

<https://notes.kodekloud.com/docs/AWS-Certified-SysOps-Administrator-Associate/Domain-2-Reliability-and-BCP/Setting-Up-S3-for-CRR>

Replicating objects - Amazon Simple Storage Service. (n.d.). Docs.aws.amazon.com.

<https://docs.aws.amazon.com/AmazonS3/latest/userguide/replication.html>

What is AWS Fault Injection Simulator? - AWS Fault Injection Simulator. (n.d.).

Docs.aws.amazon.com. <https://docs.aws.amazon.com/fis/latest/userguide/what-is.html>